

ORBIT Security Architecture

1. Introduction

ORBIT (Open Retrieval-Based Inference Toolkit) is an open-source AI gateway, retrieval engine, and agent protocol host. It can be deployed on-premises, in private cloud environments, or in isolated air-gapped networks.

ORBIT's core application code and gateway configuration features are distributed under the Apache 2.0 open-source license. Certain capabilities connect to separately operated infrastructure dependencies (e.g. external OIDC Identity Providers like Entra ID/Auth0, the self-hosted Presidio HTTP PII analyzer, cloud secret managers, or cloud object stores).

Achieving compliance for a specific deployment requires validating ORBIT's technical capabilities alongside deployment-specific operational controls, network security, host hardening, storage infrastructure, external service governance, and administrative procedures.

2. NIST SP 800-53 Rev. 5 Technical Control Mapping

This section maps ORBIT's documented features to NIST SP 800-53 (Rev. 5) control objectives using a three-part analysis:

1. **Documented Capability:** The specific feature implemented in ORBIT.
2. **Potential Control Contribution:** The NIST SP 800-53 control objective supported by the capability.

3. Deployment Evidence & Responsibilities Required: Mandatory operational procedures, infrastructure controls, and assessor evidence required.

2.1 Access Control (AC)

NIST Control	Documented Capability	Potential Control Contribution	Deployment Evidence & Responsibilities Required
AC-2 Account Management	Deny-by-Default Identity Allowlisting: <code>auth.providers.access_control: allowlist</code> enforces rule-based access control. External Entra ID and Auth0 users can be pre-cleared by email, user ID, or OIDC provider-subject before account provisioning (<code>orbit user allowlist</code> , Admin UI, <code>/auth/allowlist</code>).	Supports pre-provisioning verification and structured identity lifecycle management for federated accounts.	Evaluators must configure <code>auth.providers.access_control: allowlist</code> , verify rule synchronization, and review user provisioning logs. Reference: Authentication Guide .
AC-3 Access Enforcement	6-Role RBAC & Granular Permissions: Enforces 6 documented roles (<code>admin</code> , <code>operator</code> , <code>auditor</code> , <code>analyst</code> , <code>user-manager</code> , <code>user</code>) covering 11 discrete permissions. API keys can be bound to specific adapters, users, email allowlists, and request quotas.	Provides role-based enforcement over system routes, configuration management, and model proxy paths.	Assessors must verify role bindings in <code>users</code> and <code>api_keys</code> schema tables and review authorization test suites. Admin IP allowlisting (<code>auth.admin_ip_allowlist</code>) further restricts admin dashboard and admin-scoped API access to designated CIDR ranges, opt-in and independent of RBAC (implementation plan). References: RBAC Architecture , API Keys Guide .
AC-6 Least Privilege	OIDC Role Mapping & Adapter Scoping: Federated JWTs are cryptographically validated against configured IdPs and mapped to local ORBIT users with baseline role assignment set by <code>auth.providers.default_role</code> (defaults to <code>user</code>). Administrative permissions are assigned locally.	Enables least-privilege scoping for end-user chat/API sessions versus administrative sessions.	System administrators must audit <code>default_role</code> settings and verify that administrative permissions are granted only to vetted users. Reference: Authentication Guide .
AC-7 Unsuccessful Logon Attempts	Login Rate Limiting & Durable Account Lockout: Password and SSO login surfaces enforce configurable, cache-backed fixed-window limits using independent per-IP and normalized-username buckets, with an in-memory fallback when the cache is unavailable. Local-password accounts also persist consecutive failures and automatically lock for a configured duration; the counter is reset after a successful login or configured stale-failure window. The lockout check is applied before password hashing, including WebSocket Basic authentication.	Supports brute-force throttling and limits repeated unsuccessful authentication attempts against both source addresses and target identities. Durable, automatically expiring lockout completes this AC-7 control contribution for local-password accounts.	Login Rate Limiting evidence and Account Lockout evidence document the implementation and verification coverage. System administrators must configure <code>auth.login_rate_limit</code> and <code>auth.account_lockout</code> , verify thresholds, cache/fallback behavior, durable-counter persistence, and lockout expiry.

NIST Control	Documented Capability	Potential Control Contribution	Deployment Evidence & Responsibilities Required
AC-12 Session Termination	Allowlist Access Withdrawal: Removing or narrowing an allowlist rule revokes identity clearance. Active opaque dashboard sessions and provider JWT validation calls fail authorization on subsequent requests within the worker's cache TTL window.	Contributes to automated session and credential access revocation upon account status changes.	Evaluators must configure cache TTL values appropriately and test revocation propagation across multi-worker deployments. Self-service and admin session listing/revocation is gated on the <code>sessions.manage</code> permission (Phase 5 implementation plan). Reference: Authentication Guide .

2.2 Audit and Accountability (AU)

NIST Control	Documented Capability	Potential Control Contribution	Deployment Evidence & Responsibilities Required
AU-2 / AU-3 Event Logging & Content	Structured Audit Event Logging: Captures inference requests, authentication events, administrative changes, and API key mutations across SQLite, PostgreSQL, MongoDB, or Elasticsearch backends. Authentication coverage includes successful, failed, rate-limited, and durable-lockout password logins; dashboard authorization denials; and password changes/resets. Records timestamps, user IDs, masked keys, adapters, models, token counts, call types (<code>chat</code> , <code>embedding</code> , <code>vision</code> , <code>stt</code> , <code>tts</code> , <code>image</code> , <code>video</code>), and local cost estimates.	Provides audit event generation and detailed record content for security monitoring.	System integrators must enable <code>internal_services.audit.enabled: true</code> and configure a resilient storage backend. Authentication failure records use a fixed server-side reason taxonomy and redact passwords, hashes, tokens, and account-existence details. See Authentication Audit Trail Coverage evidence . Reference: Token Usage and Cost Tracking .
AU-6 Audit Review & Reporting	Admin Observability & Cost Dashboards: Web UI Audit viewer and Costs tab enable filtering events by user, API key, adapter, provider, and call type with historical API key masking suffix resolution.	Supports administrative audit review, triage, and usage analysis.	Assessors must verify RBAC restrictions on audit routes (<code>auditor</code> / <code>admin</code> roles) and review audit log retention procedures. Reference: Token Usage and Cost Tracking .
AU-9 Audit Protection	Separate Admin Event Clearing: Setting <code>internal_services.audit.admin_events.clear_on_startup: false</code> preserves administrative and authentication audit history across server restarts even if inference logs are cleared.	Supports separate administrative audit-retention settings.	Deployment Responsibility: Log immutability, WORM storage, tamper-evidence, and remote syslog export must be implemented at the host/database layer. Reference: Default Configuration .

NIST Control	Documented Capability	Potential Control Contribution	Deployment Evidence & Responsibilities Required
AU-10 Identity Attribution	Strict Auth Mode: Enabling <code>auth.require_authenticated_user: true</code> mandates that inference API calls carry a verified user identity alongside API keys.	Provides user-level attribution for API requests.	Deployment Responsibility: A bearer token provides attribution but not mathematical non-repudiation (tokens can be shared). Note: <code>/health</code> remains unauthenticated, and <code>/mcp</code> requires non-strict mode or separate routing. Reference: Authentication Guide .

2.3 Identification and Authentication (IA)

NIST Control	Documented Capability	Potential Control Contribution	Deployment Evidence & Responsibilities Required
IA-2 Identification & Authentication	OIDC/SSO Integration, Native TOTP 2FA & Keyring: Supports Microsoft Entra ID (Azure AD) and Auth0 OIDC SSO protocols. Password authentication uses PBKDF2-SHA256 hashing. OS Keyring integration is available for credential storage. Local password accounts can additionally enroll native TOTP-based two-factor authentication (<code>auth.two_factor.enabled</code>), with <code>required_for_roles</code> (default <code>["admin"]</code>) mandating enrollment for administrative accounts before they can obtain a full session.	Can participate in MFA enforced by the configured identity provider (federated accounts), and independently enforces a second authentication factor for local accounts, including a mandatory-MFA control for administrative roles.	Integrators must enforce MFA at the OIDC Identity Provider level for federated accounts, and configure <code>auth.two_factor</code> (<code>enabled</code> , <code>required_for_roles</code> , <code>rate_limit</code>) plus the <code>ORBIT_MFA_ENCRYPTION_KEY</code> secret for local accounts. Evidence: Two-Factor Authentication implementation plan and its verification test suite (<code>server/tests/test_auth/test_mfa.py</code> , 10 tests covering enrollment confirmation gating, blocked login without a valid TOTP/recovery code, single-use recovery-code consumption under concurrency, and required-role enrollment/self-disable enforcement). Reference: Authentication Guide .
IA-5 Authenticator Management	Local Password Policy & API Key Management: Local account creation, password changes, resets, and default-admin provisioning enforce configurable length, character-class, and common-password requirements. API keys are securely generated, stored and managed in the API-key store (<code>api_keys</code>), and masked in audit ledgers (<code>orbit...</code>). Keys can be deactivated instantly (<code>active: 0</code>), bounded by request quotas, or restricted by user/email allowlists.	Supports password policy enforcement, key management, masking, and rapid deactivation.	See Password Complexity implementation plan for the implemented policy and verification coverage. Current Implementation Note: API keys do not currently feature automatic date-based expiration (<code>expires_at</code>); key rotation must be managed procedurally. Roadmap Note (Phase 8): An implementation plan (Phase 8 API Key Expiration Roadmap) details planned support for default 90-day key lifetimes, explicit admin renewal operations, auditable non-expiring exceptions, and legacy key migration. References: API Keys Guide , SQLite Schema .

2.4 System and Communications Protection (SC)

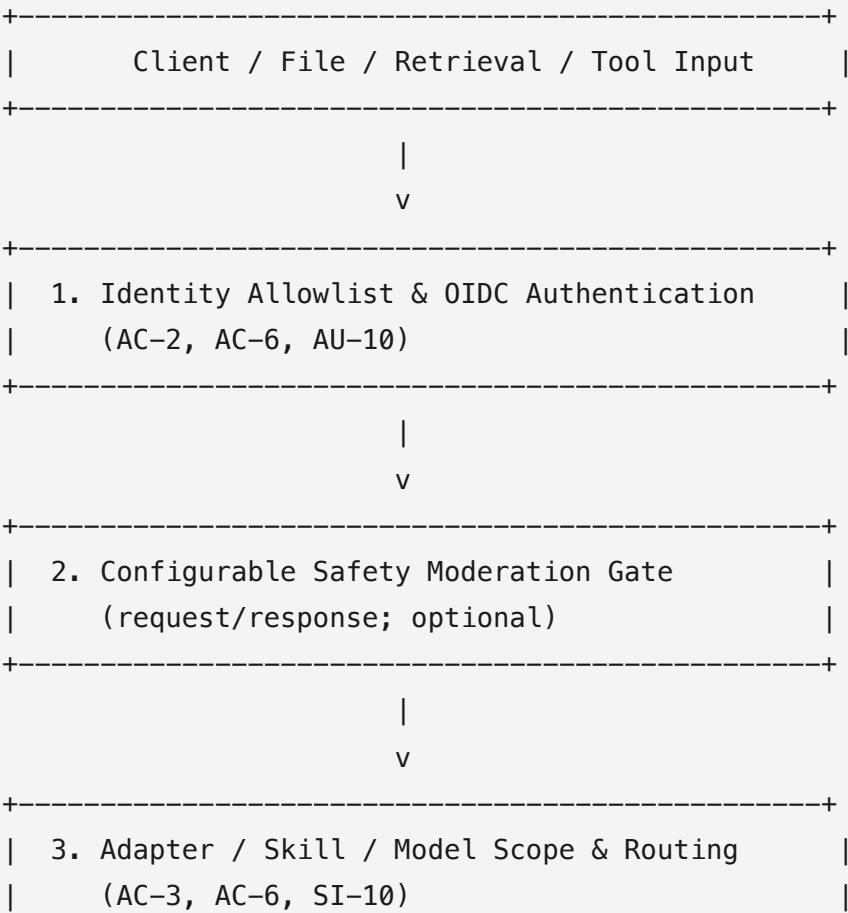
NIST Control	Documented Capability	Potential Control Contribution	Deployment Evidence & Responsibilities Required
SC-8 Transmission Confidentiality	HTTPS & TLS Encryption: Supports HTTPS over TLS 1.2 or later with forward-secrecy ciphers for REST endpoints, OpenAI-compatible proxy routes, and WebSockets (<code>/ws</code>).	Protects communications confidentiality and integrity in transit.	Operators must configure valid TLS certificates and enforce HTTPS termination at ORBIT or an upstream reverse proxy (e.g. NGINX). Reference: Server Guide .
SC-13 / SC-28 Cryptographic Storage	Opt-in File & Content Encryption: <code>files.encryption.enabled: true</code> combined with adapter <code>capabilities.requires_encryption: true</code> enforces AES-256-GCM encryption for stored file bytes, metadata sidecars, chunk text, and extracted content.	Protects uploaded document content at rest.	Roadmap Note: Cloud KMS integration, envelope encryption, and automated key rotation are documented future enhancement roadmap items. Reference: File Adapter Guide .

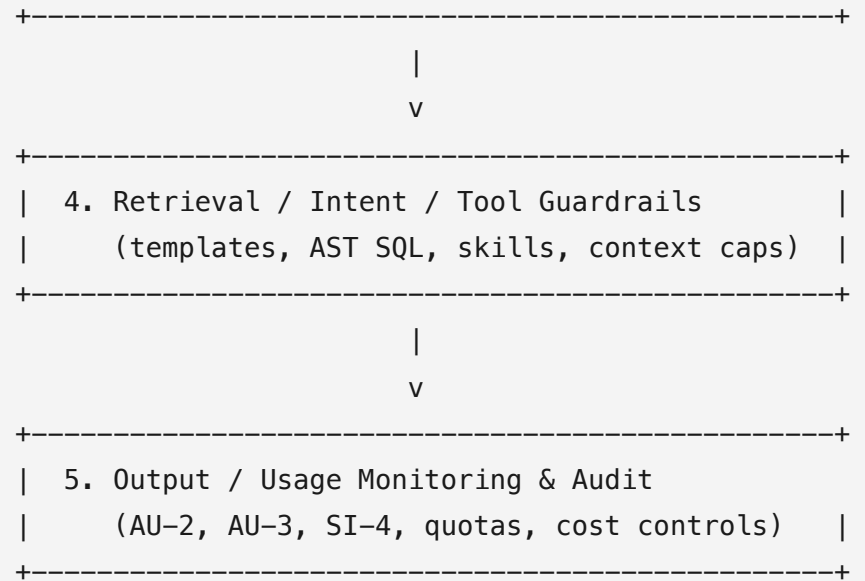
2.5 System and Information Integrity (SI)

NIST Control	Documented Capability	Potential Control Contribution	Deployment Evidence & Responsibilities Required
SI-4 System Monitoring	Metrics & Health Monitoring: Prometheus-compatible metrics endpoint (<code>/ws/metrics</code>), health checks (<code>/health</code>), worker status, circuit breakers, and rate-limiting telemetry.	Contributes to system monitoring and operational integrity tracking.	System administrators must connect <code>/ws/metrics</code> to enterprise monitoring tools (e.g. Prometheus/Grafana) and establish alerting rules. Reference: Default Configuration .
SI-10 Input Validation	Intent SQL Query Safety & File Verification: Intent-retrieval SQL execution paths parse generated queries with an AST validator enforcing single, read-only statements (<code>SELECT</code>). Uploaded files undergo MIME/magic-number checking via <code>Magika</code> .	Provides input validation over specific database query execution paths and uploaded files.	Limitations: Query guards apply specifically to intent-retrieval paths. <code>Magika</code> provides file-type verification, not antivirus/malware sandboxing or content disarm and reconstruction (CDR). Reference: Changelog (v2.15.3).

3. AI Security Guardrails & OWASP LLM Risk Mitigations

This section maps documented ORBIT capabilities to the OWASP Top 10 for LLM Applications risk areas. The mapping describes risk reduction and containment; it does not claim universal jailbreak, prompt-injection, hallucination, or unsafe-output prevention. Several controls are optional and must be enabled and configured by the deploying organization. External moderation, identity, secret-management, storage, model, and tool services remain part of the deployment authorization boundary and require separate assessment.





3.1 OWASP LLM Top 10 Risk Mitigation Mapping

LLM01: Prompt Injection

ORBIT provides layered containment controls, but no universal direct- or indirect-prompt-injection detector. Injection may arrive in user input, conversation history, uploaded documents, retrieved or web content, MCP/A2A messages, or tool results.

- **Configurable safety moderation:** When `safety.enabled: true`, ORBIT can screen requests and responses using OpenAI, Anthropic, Llama Guard 3, Shieldstral, or local PII-focused moderators. This is a policy gate, not a dedicated prompt-injection detector. The deployment must select the moderator, define policy coverage, and test inbound and outbound behavior.
- **Intent template validation and approval:** Natural-language structured-data requests match configured templates; templates can be validated and optionally require administrator approval before use.
- **Read-only query enforcement:** Generated SQL is parsed and rejected unless it is a single, read-only, size-limited statement. This contains injection attempting database modification, but applies to guarded intent-SQL paths only.

- **Adapter, skill, and model scoping:** Skills are bound to adapters, automatic skill routing is optional and disabled by default, and `allowed_models` can constrain model selection per adapter. API-key and RBAC controls further limit invocation.
- **MCP skill playbooks and context limits:** File- and database-authored playbooks, progressive loading, priority admission, and the maximum three skills/24 KB per turn reduce uncontrolled tool-context expansion. JIT skill injection occurs after a bound tool's first invocation and does not protect that initial invocation.
- **Retrieval monitoring and refusal behavior:** Retrieval confidence, candidate scores, guard rejections, disambiguation, and Misses triage expose suspicious or low-confidence routing. Document and image generation skills refuse to invent filler when required files or matching context are unavailable.

Residual risk and assessment evidence: ORBIT does not establish that retrieved or tool-returned text is instruction-free, does not cryptographically separate trusted instructions from untrusted content, and does not guarantee that an LLM follows a playbook. Assessors should require tests covering direct, indirect, multi-turn, document, web, MCP, A2A, and tool-result attacks, plus evidence of enabled moderation, routing settings, denied tool calls, guard rejections, and low-confidence retrieval review.

LLM02: Sensitive Information Disclosure

- **Request and response moderation:** Configurable moderation backends can screen requests and responses; deployment policy must define blocked categories.
- **PII detection:** Presidio supports roughly 100 configurable entity types through a self-hosted HTTP analyzer; `privacy_filter` provides an in-process, air-gapped alternative. Detected PII is blocked, not redacted.
- **Failure behavior:** Presidio failures are blocked by default through `safety.allow_on_timeout: false`; `privacy_filter` fails open on technical errors. This difference must be tested for the selected deployment.
- **Access and secret controls:** OIDC/RBAC, strict authenticated-user mode, adapter scoping, file encryption, and secret-manager resolution reduce unauthorized data access and credential exposure.
- **Grounding guard:** Document-generation skills refuse to generate filler when requested attachments are missing or unretrieved; this is not a general confidentiality guarantee.

LLM03: Supply Chain

- ORBIT supports local, self-hosted, and cloud inference providers, per-adapter provider/model overrides, and `allowed_models` restrictions.
- AWS Secrets Manager, Azure Key Vault, and GCP Secret Manager integrations can keep provider credentials out of ordinary configuration.
- YAML capability and security settings can be version-controlled, reviewed, and promoted through change management.

Limitations: These capabilities do not establish model/dependency provenance, signature verification, vulnerability scanning, or secure-update controls. Those remain deployment and supply-chain responsibilities.

LLM04: Data and Model Poisoning

- Approved retrieval paths, optional administrator approval for intent templates, read-only SQL guards, confidence bands, and Misses triage constrain or expose some unsafe retrieval behavior.
- Retrieval outcomes, guard rejections, confidence, user feedback, and audit events support review of suspicious data or model behavior.

Limitations: ORBIT does not provide general training-data provenance, corpus-poisoning detection, model-weight validation, or semantic integrity guarantees for external documents, web content, vector stores, or tools.

LLM05: Improper Output Handling

- Response moderation can block policy-violating model responses when the safety layer is enabled.
- Read-only SQL validation, Magika file-type verification, adapter/model scoping, and bounded tool-skill context provide downstream boundary controls.

Limitations: Moderation is not HTML/Markdown sanitization, output encoding, schema validation, malware scanning, sandboxing, CDR, or validation of tool arguments and downstream commands. Integrators must safely render and consume ORBIT output.

LLM06: Excessive Agency

- MCP tool skills and procedural playbooks provide explicit guidance and tool boundaries for external MCP calls.
- Skill allowlisting and adapter scoping limit which capabilities an adapter can invoke; automatic routing is optional and disabled by default.
- Context hard limits enforce a maximum of three skills/24 KB per turn, priority-based admission, and body-redacted skill audit logging.
- MCP/A2A and async integrations expand the trust boundary and require deployment-specific authorization, tool inventory, least privilege, and approval controls. A playbook does not make an external tool trustworthy.

LLM07: System Prompt Leakage

- Static prompt blocks, scoped adapters, bounded skill loading, and redacted skill-body audit records reduce accidental exposure of internal context.
- Secret-manager resolution keeps provider credentials out of prompts and ordinary configuration values.

Limitations: These controls do not guarantee that system prompts, hidden instructions, retrieved content, or tool metadata cannot be elicited. Prompt prefix stabilization is a performance optimization, not a cryptographic or mathematical jailbreak defense.

LLM08: Vector and Embedding Weaknesses

- Hybrid semantic/keyword scoring, reranking, confidence bands, intent validation, row caps, and retrieval telemetry provide retrieval controls.
- Configured vector-store backends, adapter/API-key scoping, RBAC, and optional encrypted file/content storage provide related access and storage controls.

Limitations: The documented capabilities do not establish tenant-aware authorization filtering for every vector backend, embedding-inversion resistance, poisoned-vector detection, or provenance/integrity validation. These properties must be verified for each data source and deployment.

LLM09: Misinformation

- Grounded retrieval, reranking, confidence/clarification behavior, row caps, Misses triage, and refusal to fabricate missing document context reduce some unsupported answers.
- Per-response feedback, request history, retrieval outcomes, and audit events provide review signals.

Limitations: These are grounding and review aids, not factuality proofs, source verification, citation correctness, or guarantees against hallucination. Deployment procedures should define when human review or authoritative-source validation is required.

LLM10: Unbounded Consumption

- Per-key daily/monthly quotas, priority-based throttling, rate limiting, and request telemetry constrain consumption.
- Per-turn skill/context caps, dynamic history budgeting, and configured model/media limits reduce uncontrolled token and media use.
- Local token/media cost estimation and dashboards report usage by model, provider, adapter, user, request type, and API key, with pricing staleness tracking.

Limitations: Local prices are estimates rather than provider invoices, and quota enforcement does not prevent distributed abuse across identities or keys. Operators must define aggregate tenant, network, and provider-side limits where required.

3.2 OWASP Control Configuration & Assessment Evidence

For an authorization assessment, the deploying organization should retain:

- the effective guardrail, moderator, adapter, skill, model, MCP, A2A, and retrieval configurations;
- evidence that moderation is enabled, the selected policy is approved, timeout/failure behavior is intentional, and request/response paths were tested;
- approved intent templates, adapter/skill/model allowlists, tool inventories, external-service trust decisions, and least-privilege assignments;
- prompt-injection, unsafe-output, PII, retrieval-isolation, tool-abuse, quota, and failover test results;

- audit records and monitoring alerts for moderation decisions, retrieval guard rejections, tool calls, low-confidence retrievals, quota events, and administrative changes; and
 - documented residual-risk acceptance for universal prompt-injection prevention, model/dependency provenance, corpus-poisoning detection, output sanitization, vector-store isolation, and factuality verification.
-

4. Alignment with NIST AI Risk Management Framework (AI RMF 1.0)

ORBIT's design supports organizational alignment with the four core functions of the **NIST AI RMF 1.0**:

- **GOVERN**: Enables version-controlled capability management (`config/*.yaml`), 6-role RBAC (`admin` , `operator` , `auditor` , `analyst` , `user-manager` , `user`), identity allowlists, and separate administrative audit-retention settings (`clear_on_startup: false`).
 - **MAP**: Intent template validation maps natural language user queries to validated/configured SQL/API retrieval paths and explicit tool boundaries.
 - **MEASURE**: Phase 4 intent telemetry tracks retrieval outcomes, confidence scores, and row caps, surfacing low-confidence queries in the Admin Panel **Misses** triage view.
 - **MANAGE**: Integrated circuit breakers, provider fallbacks, and hot adapter reloading enable active management of provider outages and system updates without server downtime.
-

5. Security & Governance Enhancements Roadmap

ORBIT maintains an active security architecture roadmap to extend its security controls and address operational requirements for accredited environments:

5.1 Authentication & Access Control Hardening

- **Account Lockout Controls:** Local-password accounts automatically lock after configurable consecutive failed attempts. Lockout state is durable, applies to password and WebSocket Basic-auth verification, resets after a successful login or stale-failure window, and expires automatically rather than requiring administrator unlock. Evidence: [Account Lockout implementation plan](#). This completes the account-lockout portion of the AC-7 unsuccessful-logon-attempts control contribution.
- **Expanded Audit Trail Coverage:** Authentication audit logging records redacted failed-login, rate-limit, durable-lockout, dashboard-authorization-denial, password-change, and password-reset events through the existing multi-backend audit service. Evidence: [Authentication Audit Trail Coverage implementation plan](#).
- **Session Monitoring & Revocation:** Sessions record source IP, user agent, and a throttled last-activity time. Every authenticated user can list and revoke their own sessions; a new `sessions.manage` permission lets an administrator do the same for any user, surfaced in the admin panel's user detail view. Session revocation is recorded in the audit ledger as `auth.session.revoke`. Evidence: [Session Monitoring implementation plan](#).
- **Admin Network IP Allowlisting:** CIDR-based network restriction (`auth.admin_ip_allowlist`) limiting administrative dashboard and admin-scoped API access to authorized management subnets, independent of identity/RBAC and opt-in. Loopback access is always exempt so `orbit` CLI commands against the local server are never affected, and a rule removal that would exclude the requesting administrator's own current IP requires explicit confirmation. Evidence: [Admin IP Allowlisting implementation plan](#).
- **Native Two-Factor Authentication:** TOTP-based multi-factor authentication for local password accounts, opt-in via `auth.two_factor.enabled` and mandatory for a configurable set of roles (`required_for_roles` , default `["admin"]`) - an unenrolled account in a required role cannot obtain a full session. Enrollment is confirmation-gated (a valid code must be presented before activation) and issues one-time recovery codes; login becomes a two-step exchange (password, then TOTP/recovery code) throttled independently of the password-login rate limits; an optional "remember this device" window reduces re-prompting; TOTP secrets are encrypted at rest (AES-256-GCM); and an administrator with `users.manage` can reset a locked-out user's 2FA, recorded in the audit ledger as `auth.mfa.admin_reset`. Evidence: [Two-Factor Authentication implementation plan](#). This completes the AC-7/IA-2 native-MFA control contribution for local-password accounts.
- **API Key Expiration & Lifecycle Management (Phase 8):** Enforceable key expiration (`expires_at` , 90-day default lifetime), explicit admin renewal workflows, auditable non-expiring exceptions, and legacy key migration ([Phase 8 Roadmap](#)).

5.2 Cryptography & Data Protection

- **Cloud KMS & Envelope Encryption:** Cloud KMS, envelope encryption, and key rotation: planned future enhancement; see the file-encryption roadmap ([File Encryption Roadmap](#)).

5.3 Resource & Budget Governance

- **Real-Time Cost Alerts & Notifications:** Configurable spend thresholds, budget notifications, and automated alerts for API key and tenant usage ([Cost Notifications Roadmap](#)).
-

6. Document References

- **NIST SP 800-53 Rev. 5:** [NIST CSRC Publication Detail](#)
- **NIST AI RMF 1.0:** [NIST AI Risk Management Framework](#)
- **OWASP Top 10 for LLM:** [OWASP LLM Security Project](#)
- **ORBIT Capability Matrix:** [ORBIT Capability Matrix](#)
- **ORBIT Authentication Guide:** [Authentication Guide](#)
- **ORBIT PII Moderation Guide:** [PII Moderation Guide](#)
- **ORBIT Role-Based Access Control:** [RBAC Architecture](#)